

Deconstructing HijackLoader

Technical Breakdown of the 2026 Variant (UKqqACLUALIsaSR)

Reverse Engineering & Infrastructure Extraction Methodology

Phase 1: Automated Triage

- **Objective:** Identify variants statically without triggering execution.
- **The Methodology:** Utilizing `radare2` and `rabin2` bash scripts to hunt structural anomalies.
- **Key Identification Markers:**
 - **IDAT/IHDR Chunks:** Found via `rabin2 -z`, indicating steganographic image payload hiding.
 - **Magic Signatures:** Searching for specific hex patterns (C6A579EA) via `r2 -c "/x"`.

Phase 2: Bypassing EDR / SIMD Encryption

- **The Evasion Tactic:** Decryption occurs outside of standard execution loops to avoid heuristic detection.
- **The Mechanism:**
 - Execution is intentionally hijacked into `VCRUNTIME140.dll`.
 - Malware abuses the `____std_exception_copy` constructor.
 - Utilizes 128-bit **SIMD registers (XMM)** and instructions (`xorps`, `movups`) for concurrent block decryption.
- *Why it works:* EDR sensors rarely hook standard C++ exception libraries due to massive performance overhead.

Phase 3: Environmental Keying

- The decryption routine requires a dynamic seed to function.
- Using `rabin2 -0`, we mapped a high-entropy "slack space" overlay starting at memory address `0x108000`.
- **The Master Key Extraction:**
 - The loader parses its own PE header to locate the Microsoft Digital Signature (`0x108090`).
 - It extracts the **ASN.1 SEQUENCE marker (0x30)** to use as the master decryption key.

Phase 4: C2 Infrastructure Mapping

- Post-decryption, IPs are not stored as plain strings (e.g., "104.151...").
- They populate an **Indirect Addressing Table** at 0x00101200.
- Using `pxw 32` in radare2 dumps raw 32-bit little-endian integers.
- **The Python Unpacker:**
 - Uses `struct.pack("<I")` to translate memory structures back into standard IPv4 octets.
 - Identifies ports by checking for specific Big-Endian marker bytes (0xBB, 0xB8).

Extracted Indicators of Compromise

Index	Original Hex	Decoded Target

0	0xe9768	IP: 104.151.14.0
1	0x1b950	IP: 80.185.1.0
2	0x1bb4b	PORT: 19387
3	0xe904c	IP: 76.144.14.0
4	0x101210	IP: 16.18.16.0
5	0x1bb50	PORT: 20667
6	0x1bbb1	PORT: 45499
7	0xe75d4	IP: 212.117.14.0

Defensive Strategy: Monitor high-range networking ports (19000-21000) and flag XMM register anomalies inside `VCRUNTIME140.dll` exception handlers.